

プロジェクト名:

認証・認可基盤に対する攻撃検証サンドボックスの開発

丸山 拓真

これは学内のKDIX.Labのチャンネルで報告するためにまとめたものです。

1.何を作るか

1.1 背景

情報化社会において、多くのデータはアカウントと紐付けられて管理されている。アカウントが本人かどうかを確認する技術を認証と呼び、サービス間でどの情報取得や操作を許可するかを決定する枠組みを認可と呼ぶ。

特に近年では、外部サービスとの連携をするための枠組みとして、OAuth 2.0が広く利用されている。OAuth 2.0の仕様はRFC 6749(The OAuth 2.0 Authorization Framework)として定義されており、多くのWebサービスで用いられている。

しかし、認証・認可基盤の実装は、一般のWebアプリケーションの機能として比較的難易度が高く、複雑である。認可処理では、アクセストークンやリフレッシュトークン、セッションの保存や状態、リダイレクトの処理など、複数の要素が相互に関係しながら動作する。また、これらの処理は、単一のサーバー内で完結するものではなく、ブラウザ、認可サーバー、リソースサーバーなど、複数の処理モジュールを横断して進行する。

認可処理では、以下のような特徴を持つ処理が多く存在する。

- リダイレクトなど、複数のサーバーやエンドポイントをまたいで進行する処理
- セッションやstateなど、一時的な状態を照合する処理
- 有効期限や失効など、時間経過に依存する処理
- 認可コードやトークンの再利用・再送を防ぐ必要がある処理
- リダイレクト先や入力値を厳密に検証する処理

このような性質のため、認可基盤の脆弱性は、通常の単体テストや結合テストでは検証しにくい。例えば、トークンの期限切れや、リクエストの再送による意図しない不整合は、時間経過や複数回のリクエストを伴うため、専用の検証環境や特別な準備をしなければ再現が難しい。

また、認可においては以下のような攻撃が存在する。

- リダイレクト先の検証不備を悪用する攻撃
- stateなどの照合不備を悪用する攻撃
- 認可コードの盗用・再利用を狙う攻撃
- アクセストークンの再利用や漏洩を悪用する攻撃
- リフレッシュトークンの不正利用を狙う攻撃

万が一これらの攻撃を防げなければ、認可の性質上、権限奪取や情報漏洩につながりうる。アカウントに紐付いた情報やデータの漏洩、サービスの信頼性低下、経済的損失を招くおそれがあるため、認証・認可基盤は特に慎重な実装と検証が求められる。

また、認証・認可基盤は、そのサービスのセキュリティの中核を担うため、本番環境で攻撃的なテストは原則として避けるべきである。そのため、検証のために専用環境を用意する必要があるが、この準備には、時間・工数・費用など、総じてコストがかかるため、企業の経営判断として、難しい意思決定が必要になることも考えられる。

1.1.1 なぜ私がこの問題に取り組むのか・時間を費やすのか

本プロジェクトの着想は、提案者の丸山が実際に認可基盤の開発に関わった経験から生まれたものである。株式会社トリドリにおいては、共通基盤を扱うチームに所属しており、認可基盤の開発に携わる中で、OAuthを用いた外部ログイン処理やトークン管理の実装に携わる機会があった。認証・認可処理は、プロダクトの中でも特に複雑な領域であり、その基盤を適切に設計・実装し、十分な安全性を確保するための検証を進めることも容易ではなかった。OAuth関連のタスクについて、その要求を正確に読み解き、実装し、検証するまでの一連の過程に非常に苦労したことを記憶している。この経験を受け、認可処理を効率よく検証する仕組みの必要性を強く感じ、本プロジェクトの着想に至った。

1.2 目的

本プロジェクトは、認証・認可基盤の実装コードをもとに、攻撃シナリオを実行できる、軽量のサンドボックス型の検証環境を自動構成する仕組みを開発する。対象はOAuth2.0におけるクライアント・認可サーバー・リソースサーバーを中心とし、OpenID Connectへの拡張可能性も含めて設計する。これにより、従来は準備コストや時間的制約のために十分に行うことが難しかった、時間経過・再送・状態不整合を含む検証を、CI上で柔軟かつ継続的に実施できるようにする。なお、本プロジェクトにおける「攻撃」とは、認証・認可基盤に対して、不正値の入力、入力の欠落、リクエストの再送、順序を崩したリクエスト列、時間経過後の再利用、外部エンドポイントからの異常応答を含む条件を与え、想定外の状態遷移や不正な副作用が発生しないかを検証することを指す。すなわち、一般的な侵入テスト全般ではなく、認証・認可基盤に特有のプロトコル上・実装上の不備を、再現可能なシナリオとして検証するものである。

1.3 目玉となる機能と実現手法

本プロジェクトは、認可処理の抽出、攻撃シナリオの生成、時間進行を考慮した攻撃検証、リトライ攻撃に関する検証、CI環境での継続実行、およびGUIによる可視化を主要な機能として実装する。以下に、それぞれの機能について述べる。

1.3.1 サンドボックス認可基盤攻撃検証環境

本機能では、認証・認可基盤の実装コードから認可処理に関わる要素を抽出し、攻撃シナリオを実行可能なサンドボックス検証環境を構成する。この仕組みにより、開発者は実装とは別に検証用コードを記述することなく、実際の認可処理の挙動を再現しながら攻撃シナリオを実行できるようになる。この機能は、現在開発しているプロトタイプの実装に基づき、以下の手順で実現する。

1. 各言語に対応する静的解析・構文解析ライブラリを用いて、構文木レベルまで解析する。なお、プロジェクト期間中はTypeScriptのみを対象とする。
2. 構文木から、認可基盤を成り立たせるための重要な処理群を検出する。条件分岐、関数呼び出しなど、その言語の基礎的な処理部分に加え、ルーティングやセッション保存、クエリパラメーターのバリテーションなどフロントエンド領域で重要なものや、データベースとの読み書きなどの処理を抽出、列挙する。この処理によって、各言語ネイティブの部分と、後続の処理を分離することができる。
3. サンドボックス環境において実行可能な形に変換し、再現する。これにより、実際の認証・認可処理の流れを擬似的に再現しながら、攻撃シナリオの実行や状態遷移の検証を行うことができる。

このように、高速かつ最小の環境で実行・検証できるようにすることで、1.3.6で述べる継続的インテグレーションへの導入も可能になる。

1.3.2 時間軸・時間進行を考慮した攻撃検証

前述した通り、認証・認可における要素として、セッションやアクセストークンの有効期限など、「時間の進行」があげられる。この検証が不十分な場合、アクセストークンやリフレッシュトークンの悪用など、時間経過に起因する脆弱性が発生する。しかしながら、この検証は単純な単体テストやE2Eテストでは難しい。この問題を解決するために、時間を人工的に進める仕組みを導入し、時間経過を前提とした認可処理の検証を容易にする。

1.3.3 意図しないリトライや、不正な重複使用の検証

```
GitHub Appトークンエンドポイントのレスポンス: { status: 200, statusText: '' }
GitHub Appリフレッシュトークンを取得しました。 { refreshTokenPreview: 'rotate...' }
GitHub Appアクセストークンを取得しました。 { accessTokenPreview: 'sandbo...' }
GitHub Appリフレッシュトークンを取得しました。 { refreshTokenPreview: 'rotate...' }
codeまたはstateが不足しています。 { code: 'sandbox-code', state: null }
GitHub Appトークンエンドポイントのレスポンス: { status: 200, statusText: '' }
GitHub Appリフレッシュトークンを取得しました。 { refreshTokenPreview: 'rotate...' }
GitHub Appアクセストークンを取得しました。 { accessTokenPreview: 'sandbo...' }
GitHub Appリフレッシュトークンを取得しました。 { refreshTokenPreview: 'rotate...' }
stateの検証に失敗しました。 { receivedState: 'sandbox-state', expectedState: undefined }
stateの検証に失敗しました。 {
  receivedState: 'sandbox-state-tampered',
  expectedState: 'sandbox-state'
}
GitHub Appトークンエンドポイントのレスポンス: { status: 200, statusText: '' }
GitHub Appリフレッシュトークンを取得しました。 { refreshTokenPreview: 'rotate...' }
GitHub Appアクセストークンを取得しました。 { accessTokenPreview: 'sandbo...' }
GitHub Appリフレッシュトークンを取得しました。 { refreshTokenPreview: 'rotate...' }
stateの検証に失敗しました。 { receivedState: 'sandbox-state', expectedState: undefined }
stateの検証に失敗しました。 { receivedState: 'state-before-authorize', expectedState: undefined }
stateの検証に失敗しました。 { receivedState: 'sandbox-state', expectedState: undefined }
```

図1 サンドボックス環境において攻撃検証をしている様子

```
apps/auth-app/app/routes/auth/github-app/callback.ts
216 216 217 218
219 220 221 222
223 224 225
226 227 228
229 230 231 232
233 234 235
236 237 238
239 240 241 242
243 244 245
246 247 248
249 250 251 252
253 254 255
256 257 258
259 260 261 262
263 264 265
266 267 268
269 270 271 272
273 274 275
276 277 278
279 280 281 282
283 284 285
286 287 288
289 290 291 292
293 294 295
296 297 298
299 300 301 302
303 304 305
306 307 308
309 310 311 312
313 314 315
316 317 318
319 320 321 322
323 324 325
326 327 328
329 330 331 332
333 334 335
336 337 338
339 340 341 342
343 344 345
346 347 348
349 350 351 352
353 354 355
356 357 358
359 360 361 362
363 364 365
366 367 368
369 370 371 372
373 374 375
376 377 378
379 380 381 382
383 384 385
386 387 388
389 390 391 392
393 394 395
396 397 398
399 400 401 402
403 404 405
406 407 408
409 410 411 412
413 414 415
416 417 418
419 420 421 422
423 424 425
426 427 428
429 430 431 432
433 434 435
436 437 438
439 440 441 442
443 444 445
446 447 448
449 450 451 452
453 454 455
456 457 458
459 460 461 462
463 464 465
466 467 468
469 470 471 472
473 474 475
476 477 478
479 480 481 482
483 484 485
486 487 488
489 490 491 492
493 494 495
496 497 498
499 500 501 502
503 504 505
506 507 508
509 510 511 512
513 514 515
516 517 518
519 520 521 522
523 524 525
526 527 528
529 530 531 532
533 534 535
536 537 538
539 540 541 542
543 544 545
546 547 548
549 550 551 552
553 554 555
556 557 558
559 560 561 562
563 564 565
566 567 568
569 570 571 572
573 574 575
576 577 578
579 580 581 582
583 584 585
586 587 588
589 590 591 592
593 594 595
596 597 598
599 600 601 602
603 604 605
606 607 608
609 610 611 612
613 614 615
616 617 618
619 620 621 622
623 624 625
626 627 628
629 630 631 632
633 634 635
636 637 638
639 640 641 642
643 644 645
646 647 648
649 650 651 652
653 654 655
656 657 658
659 660 661 662
663 664 665
666 667 668
669 670 671 672
673 674 675
676 677 678
679 680 681 682
683 684 685
686 687 688
689 690 691 692
693 694 695
696 697 698
699 700 701 702
703 704 705
706 707 708
709 710 711 712
713 714 715
716 717 718
719 720 721 722
723 724 725
726 727 728
729 730 731 732
733 734 735
736 737 738
739 740 741 742
743 744 745
746 747 748
749 750 751 752
753 754 755
756 757 758
759 760 761 762
763 764 765
766 767 768
769 770 771 772
773 774 775
776 777 778
779 780 781 782
783 784 785
786 787 788
789 790 791 792
793 794 795
796 797 798
799 800 801 802
803 804 805
806 807 808
809 810 811 812
813 814 815
816 817 818
819 820 821 822
823 824 825
826 827 828
829 830 831 832
833 834 835
836 837 838
839 840 841 842
843 844 845
846 847 848
849 850 851 852
853 854 855
856 857 858
859 860 861 862
863 864 865
866 867 868
869 870 871 872
873 874 875
876 877 878
879 880 881 882
883 884 885
886 887 888
889 890 891 892
893 894 895
896 897 898
899 900 901 902
903 904 905
906 907 908
909 910 911 912
913 914 915
916 917 918
919 920 921 922
923 924 925
926 927 928
929 930 931 932
933 934 935
936 937 938
939 940 941 942
943 944 945
946 947 948
949 950 951 952
953 954 955
956 957 958
959 960 961 962
963 964 965
966 967 968
969 970 971 972
973 974 975
976 977 978
979 980 981 982
983 984 985
986 987 988
989 989 990 991 992
993 994 995
996 997 998
999 1000 1001 1002
1003 1004 1005
1006 1007 1008
1009 1010 1011 1012
1013 1014 1015
1016 1017 1018
1019 1020 1021 1022
1023 1024 1025
1026 1027 1028
1029 1030 1031 1032
1033 1034 1035
1036 1037 1038
1039 1040 1041 1042
1043 1044 1045
1046 1047 1048
1049 1050 1051 1052
1053 1054 1055
1056 1057 1058
1059 1060 1061 1062
1063 1064 1065
1066 1067 1068
1069 1070 1071 1072
1073 1074 1075
1076 1077 1078
1079 1080 1081 1082
1083 1084 1085
1086 1087 1088
1089 1090 1091 1092
1093 1094 1095
1096 1097 1098
1099 1100 1101 1102
1103 1104 1105
1106 1107 1108
1109 1110 1111 1112
1113 1114 1115
1116 1117 1118
1119 1120 1121 1122
1123 1124 1125
1126 1127 1128
1129 1130 1131 1132
1133 1134 1135
1136 1137 1138
1139 1140 1141 1142
1143 1144 1145
1146 1147 1148
1149 1150 1151 1152
1153 1154 1155
1156 1157 1158
1159 1160 1161 1162
1163 1164 1165
1166 1167 1168
1169 1170 1171 1172
1173 1174 1175
1176 1177 1178
1179 1180 1181 1182
1183 1184 1185
1186 1187 1188
1189 1190 1191 1192
1193 1194 1195
1196 1197 1198
1199 1200 1201 1202
1203 1204 1205
1206 1207 1208
1209 1210 1211 1212
1213 1214 1215
1216 1217 1218
1219 1220 1221 1222
1223 1224 1225
1226 1227 1228
1229 1230 1231 1232
1233 1234 1235
1236 1237 1238
1239 1240 1241 1242
1243 1244 1245
1246 1247 1248
1249 1250 1251 1252
1253 1254 1255
1256 1257 1258
1259 1260 1261 1262
1263 1264 1265
1266 1267 1268
1269 1270 1271 1272
1273 1274 1275
1276 1277 1278
1279 1280 1281 1282
1283 1284 1285
1286 1287 1288
1289 1290 1291 1292
1293 1294 1295
1296 1297 1298
1299 1300 1301 1302
1303 1304 1305
1306 1307 1308
1309 1310 1311 1312
1313 1314 1315
1316 1317 1318
1319 1320 1321 1322
1323 1324 1325
1326 1327 1328
1329 1330 1331 1332
1333 1334 1335
1336 1337 1338
1339 1340 1341 1342
1343 1344 1345
1346 1347 1348
1349 1350 1351 1352
1353 1354 1355
1356 1357 1358
1359 1360 1361 1362
1363 1364 1365
1366 1367 1368
1369 1370 1371 1372
1373 1374 1375
1376 1377 1378
1379 1380 1381 1382
1383 1384 1385
1386 1387 1388
1389 1390 1391 1392
1393 1394 1395
1396 1397 1398
1399 1400 1401 1402
1403 1404 1405
1406 1407 1408
1409 1410 1411 1412
1413 1414 1415
1416 1417 1418
1419 1420 1421 1422
1423 1424 1425
1426 1427 1428
1429 1430 1431 1432
1433 1434 1435
1436 1437 1438
1439 1440 1441 1442
1443 1444 1445
1446 1447 1448
1449 1450 1451 1452
1453 1454 1455
1456 1457 1458
1459 1460 1461 1462
1463 1464 1465
1466 1467 1468
1469 1470 1471 1472
1473 1474 1475
1476 1477 1478
1479 1480 1481 1482
1483 1484 1485
1486 1487 1488
1489 1490 1491 1492
1493 1494 1495
1496 1497 1498
1499 1500 1501 1502
1503 1504 1505
1506 1507 1508
1509 1510 1511 1512
1513 1514 1515
1516 1517 1518
1519 1520 1521 1522
1523 1524 1525
1526 1527 1528
1529 1530 1531 1532
1533 1534 1535
1536 1537 1538
1539 1540 1541 1542
1543 1544 1545
1546 1547 1548
1549 1550 1551 1552
1553 1554 1555
1556 1557 1558
1559 1560 1561 1562
1563 1564 1565
1566 1567 1568
1569 1570 1571 1572
1573 1574 1575
1576 1577 1578
1579 1580 1581 1582
1583 1584 1585
1586 1587 1588
1589 1590 1591 1592
1593 1594 1595
1596 1597 1598
1599 1600 1601 1602
1603 1604 1605
1606 1607 1608
1609 1610 1611 1612
1613 1614 1615
1616 1617 1618
1619 1620 1621 1622
1623 1624 1625
1626 1627 1628
1629 1630 1631 1632
1633 1634 1635
1636 1637 1638
1639 1640 1641 1642
1643 1644 1645
1646 1647 1648
1649 1650 1651 1652
1653 1654 1655
1656 1657 1658
1659 1660 1661 1662
1663 1664 1665
1666 1667 1668
1669 1670 1671 1672
1673 1674 1675
1676 1677 1678
1679 1680 1681 1682
1683 1684 1685
1686 1687 1688
1689 1690 1691 1692
1693 1694 1695
1696 1697 1698
1699 1700 1701 1702
1703 1704 1705
1706 1707 1708
1709 1710 1711 1712
1713 1714 1715
1716 1717 1718
1719 1720 1721 1722
1723 1724 1725
1726 1727 1728
1729 1730 1731 1732
1733 1734 1735
1736 1737 1738
1739 1740 1741 1742
1743 1744 1745
1746 1747 1748
1749 1750 1751 1752
1753 1754 1755
1756 1757 1758
1759 1760 1761 1762
1763 1764 1765
1766 1767 1768
1769 1770 1771 1772
1773 1774 1775
1776 1777 1778
1779 1780 1781 1782
1783 1784 1785
1786 1787 1788
1789 1790 1791 1792
1793 1794 1795
1796 1797 1798
1799 1800 1801 1802
1803 1804 1805
1806 1807 1808
1809 1810 1811 1812
1813 1814 1815
1816 1817 1818
1819 1820 1821 1822
1823 1824 1825
1826 1827 1828
1829 1830 1831 1832
1833 1834 1835
1836 1837 1838
1839 1840 1841 1842
1843 1844 1845
1846 1847 1848
1849 1850 1851 1852
1853 1854 1855
1856 1857 1858
1859 1860 1861 1862
1863 1864 1865
1866 1867 1868
1869 1870 1871 1872
1873 1874 1875
1876 1877 1878
1879 1880 1881 1882
1883 1884 1885
1886 1887 1888
1889 1890 1891 1892
1893 1894 1895
1896 1897 1898
1899 1900 1901 1902
1903 1904 1905
1906 1907 1908
1909 1910 1911 1912
1913 1914 1915
1916 1917 1918
1919 1920 1921 1922
1923 1924 1925
1926 1927 1928
1929 1930 1931 1932
1933 1934 1935
1936 1937 1938
1939 1940 1941 1942
1943 1944 1945
1946 1947 1948
1949 1950 1951 1952
1953 1954 1955
1956 1957 1958
1959 1960 1961 1962
1963 1964 1965
1966 1967 1968
1969 1970 1971 1972
1973 1974 1975
1976 1977 1978
1979 1980 1981 1982
1983 1984 1985
1986 1987 1988
1989 1990 1991 1992
1993 1994 1995
1996 1997 1998
1999 2000 2001 2002
2003 2004 2005
2006 2007 2008
2009 2010 2011 2012
2013 2014 2015
2016 2017 2018
2019 2020 2021 2022
2023 2024 2025
2026 2027 2028
2029 2030 2031 2032
2033 2034 2035
2036 2037 2038
2039 2040 2041 2042
2043 2044 2045
2046 2047 2048
2049 2050 2051 2052
2053 2054 2055
2056 2057 2058
2059 2060 2061 2062
2063 2064 2065
2066 2067 2068
2069 2070 2071 2072
2073 2074 2075
2076 2077 2078
2079 2080 2081 2082
2083 2084 2085
2086 2087 2088
2089 2090 2091 2092
2093 2094 2095
2096 2097 2098
2099 2100 2101 2102
2103 2104 2105
2106 2107 2108
2109 2110 2111 2112
2113 2114 2115
2116 2117 2118
2119 2120 2121 2122
2123 2124 2125
2126 2127 2128
2129 2130 2131 2132
2133 2134 2135
2136 2137 2138
2139 2140 2141 2142
2143 2144 2145
2146 2147 2148
2149 2150 2151 2152
2153 2154 2155
2156 2157 2158
2159 2160 2161 2162
2163 2164 2165
2166 2167 2168
2169 2170 2171 2172
2173 2174 2175
2176 2177 2178
2179 2180 2181 2182
2183 2184 2185
2186 2187 2188
2189 2190 2191 2192
2193 2194 2195
2196 2197 2198
2199 2200 2201 2202
2203 2204 2205
2206 2207 2208
2209 2210 2211 2212
2213 2214 2215
2216 2217 2218
2219 2220 2221 2222
2223 2224 2225
2226 2227 2228
2229 2230 2231 2232
2233 2234 2235
2236 2237 2238
2239 2240 2241 2242
2243 2244 2245
2246 2247 2248
2249 2250 2251 2252
2253 2254 2255
2256 2257 2258
2259 2260 2261 2262
2263 2264 2265
2266 2267 2268
2269 2270 2271 2272
2273 2274 2275
2276 2277 2278
2279 2280 2281 2282
2283 2284 2285
2286 2287 2288
2289 2290 2291 2292
2293 2294 2295
2296 2297 2298
2299 2300 2301 2302
2303 2304 2305
2306 2307 2308
2309 2310 2311 2312
2313 2314 2315
2316 2317 2318
2319 2320 2321 2322
2323 2324 2325
2326 2327 2328
2329 2330 2331 2332
2333 2334 2335
2336 2337 2338
2339 2340 2341 2342
2343 2344 2345
2346 2347 2348
2349 2350 2351 2352
2353 2354 2355
2356 2357 2358
2359 2360 2361 2362
2363 2364 2365
2366 2367 2368
2369 2370 2371 2372
2373 2374 2375
2376 2377 2378
2379 2380 2381 2382
2383 2384 2385
2386 2387 2388
2389 2390 2391 2392
2393 2394 2395
2396 2397 2398
2399 2400 2401 2402
2403 2404 2405
2406 2407 2408
2409 2410 2411 2412
2413 2414 2415
2416 2417 2418
2419 2420 2421 2422
2423 2424 2425
2426 2427 2428
2429 2430 2431 2432
2433 2434 2435
2436 2437 2438
2439 2440 2441 2442
2443 2444 2445
2446 2447 2448
2449 2450 2451 2452
2453 2454 2455
2456 2457 2458
2459 2460 2461 2462
2463 2464 2465
2466 2467 2468
2469 2470 2471 2472
2473 2474 2475
2476 2477 2478
2479 2480 2481 2482
2483 2484 2485
2486 2487 2488
2489 2490 2491 2492
2493 2494 2495
2496 2497 2498
2499 2500 2501 2502
2503 2504 2505
2506 2507 2508
2509 2510 2511 2512
2513 2514 2515
2516 2517 2518
2519 2520 2521 2522
2523 2524 2525
2526 2527 2528
2529 2530 2531 2532
2533 2534 2535
2536 2537 2538
2539 2540 2541 2542
2543 2544 2545
2546 2547 2548
2549 2550 2551 2552
2553 2554 2555
2556 2557 2558
2559 2560 2561 2562
2563 2564 2565
2566 2567 2568
2569 2570 2571 2572
2573 2574 2575
2576 2577 2578
2579 2580 2581 2582
2583 2584 2585
2586 2587 2588
2589 2590 2591 2592
2593 2594 2595
2596 2597 2598
2599 2600 2601 2602
2603 2604 2605
2606 2607 2608
2609 2610 2611 2612
2613 2614 2615
2616 2617 2618
2619 2620 2621 2622
2623 2624 2625
2626 2627 2628
2629 2630 2631 2632
2633 2634 2635
2636 2637 2638
2639 2640 2641 2642
2643 2644 2645
2646 2647 2648
2649 2650 2651 2652
2653 2654 2655
2656 2657 2658
2659 2660 2661 2662
2663 2664 2665
2666 2667 2668
2669 2670 2671 2672
2673 2674 2675
2676 2677 2678
2679 2680 2681 2682
2683 2684 2685
2686 2687 2688
2689 2690 2691 2692
2693 2694 2695
2696 2697 2698
2699 2700 2701 2702
2703 2704 2705
2706 2707 2708
2709 2710 2711 2712
2713 2714 2715
2716 2717 2718
2719 2720 2721 2722
2723 2724 2725
2726 2727 2728
2729 2730 2731 2732
2733 2734 2735
2736 2737 2738
2739 
```

複数の観点から安全性を確認できる仕組みを構築する。

1.3.6 GitHub Actions等によるCI実行

検証ツールは、開発者にとって最小限の負担で使えることが望ましい。初期設定以外の開発プロセスでは、開発者に都度検証ツールを手動実行させるような負担も極力減らすべきである。これを実現するため、現代の開発においては、GitHub Actionsなどを用いた継続的インテグレーション(Continuous Integration)、通称「CI」を用いて開発を進めることが多い。また、企業における開発においては、リーダーなどによるレビューが必要になることが多く、その過程としてPull Requestの作成をすることが一般的である。CIツールは、実装者とレビューヤーが容易にLintツールやテストツールの検証の結果を確認することができ、その結果を元に、マージするかやリジェクトするかなどの意思決定に寄与している。

本ツールも、Pull Request作成者とレビューヤーの双方が容易に結果を確認できるように、GitHub Actionsにおいて実行することのできる設計にし、認証・認可基盤を開発する者にとって最小限の労力で利用できるようにする。

1.3.7 攻撃シナリオの可視化・編集GUIソフトウェア

本ツールでは、攻撃シナリオとその実行結果を、状態遷移や時間進行の流れとして可視化するソフトウェアも開発する。認証・認可基盤の検証では、単に成功・失敗の結果を見るだけではなく、どの時点で、どの状態が、どの入力によって変化したかを把握することが重要である。そこで、GUIにより、攻撃シナリオ、時間経過、状態変化を視覚的に確認できるようにし、開発者やレビューヤーが問題箇所を把握しやすくする。

1.4 ユースケース

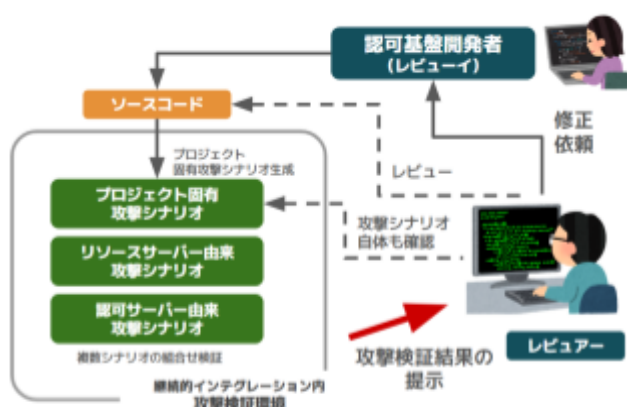


図4 レビューに関するユースケース

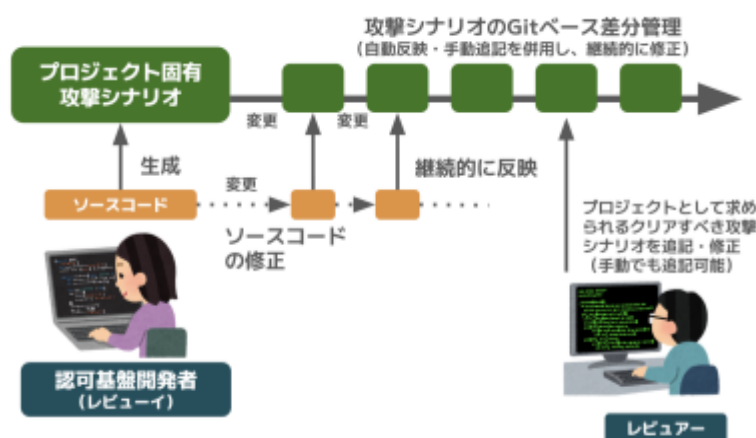


図5 攻撃シナリオのGitベース差分管理

図4に、レビューに関するユースケースを示す。認可基盤の開発者が実装したソースコードに対して、本ツールは機械的にプロジェクト固有の攻撃シナリオを生成する。このとき、攻撃シナリオ自体もレビュー対象として扱うことで、

コードの変更だけでなく、どの観点で安全性を確認したかも共有できるようにする。さらに、認可サーバーやリソースサーバーに関して求められる安全基準や、開発チーム・レビューアが確認したい観点に対応する攻撃シナリオを外部から入力し、それらを組み合わせて検証することも想定している。また、図5に示すように、攻撃シナリオはソースコードの変更に従って継続的に更新され、必要に応じて人手で追記・修正されることを想定している。

1.5 プロトタイプ

1.5.1 検証対象となる認可基盤の試作

開発リポジトリ: <https://github.com/Verification-Auth-Service/sample-auth-app>

検証対象として、実際にOAuth 2.0を用いた認可処理を備えたWebアプリケーションを試作した。実際に動作する認可処理を対象に検証基盤を作ることで、本プロジェクトが現実の実装に対して適用可能であることを確認している。フレームワークとしてはReact Router(旧Remix.js)を、言語はTypeScriptを用いている。

1.5.2 第1段階プロトタイプ

開発リポジトリ: <https://github.com/Verification-Auth-Service/typeauth>

第1段階プロトタイプでは、TypeScript・TSXで記述された、認証・認可周りの実装コードを静的解析し、認可処理をJSON表現および独自のDSLレポートへ変換するプロトタイプを開発した。具体的には、TypeScript Compiler APIを用いてソースコードを解析し、処理の流れを抽出する仕組みを作成した。

このプロトタイプでは、条件分岐、return、throw、redirect、URL、ルーティング、セッション操作など、認可にとって重要な処理をイベント列として抽出し、関数単位のフローや、HTTPエンドポイント単位の構造へ再構成できるようにした。また、セッションについても、OAuthにおけるStateなどの情報を手がかりとして、OAuthに準じたフローを抽出する機構も試作した。さらに、抽出したイベント列をもとに、人間でも読み解きやすくコンピュータも処理しやすい中置記法表現によるDSLを自動作成する仕組みも実装した。これにより、実装コードを出発点として認可処理を状態遷移として扱い、モデル検査に繋げる手法を模索した。しかしながら、これは一般的なモデル検査も抱えている問題ではあるが、状態遷移に対して完璧なモデル検査を実施しようとすると、状態数が急速に爆発し、CIツールとして要求される速度を満たすことは難しいことがわかった。また副作用が多い認可基盤について、安定して状態遷移に落とし込むことも困難であることがわかった。

1.5.3 第2段階プロトタイプ

開発リポジトリ: <https://github.com/Verification-Auth-Service/call-liner>

第1段階プロトタイプでの反省点を踏まえ、第1段階で得た静的解析基盤は活かしつつ、第2段階ではモデル検査を用いるのではなく、サンドボックス上で攻撃シナリオを軽量に実行できるツールとして方針を転換した。

このプロトタイプでは、認可基盤の挙動を軽量な環境で再現し、攻撃シナリオを直接実行できるようにした。特に、セッションなど、認可基盤に特有の問題を重点的に検証対象として扱える構成としている。具体的な攻撃の内容としては、主にOAuthクライアント側のコールバック処理を対象に、入力欠落、stateの改ざん、同一リクエストの再送、時間経過後の再利用、外部トークンエンドポイントの異常応答などを与える検証が可能である。一方、現時点での対象はクライアント側に寄っているため、本プロジェクトではこれをリソースサーバー側へも拡張し、アクセストークンやBearerトークンの検証、有効期限、再利用および不正な副作用まで扱えるようにする。さらに、攻撃シナリオについても、認証・認可基盤に特有の異常系・悪用系ケースを段階的に拡充していく。

また、このプロトタイプでの実装方式は軽量に実行できるため、継続的インテグレーションへの導入も見据えたものとなっている。

1.5.4 GitHub Actionsにおける実行

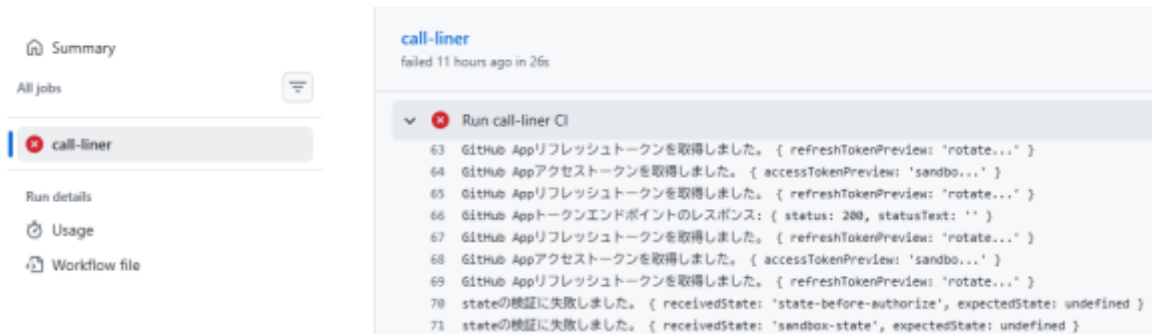


図6：CIツールとしての実行で、失敗を報告している様子

CIが成功するデモ：<https://github.com/Verification-Auth-Service/sample-auth-app/pull/82>

CIがエラーを出力するデモ：<https://github.com/Verification-Auth-Service/sample-auth-app/pull/81>

第2段階プロトタイプについては、GitHub Actions上で実行可能な構成として試作している。これにより、本プロジェクトが、Pull Requestベースの実際の開発プロセスに組み込める見通しを得ることができた。

1.5.5 可視化GUIソフトウェアプロトタイプ

攻撃シナリオ、時間進行、状態変化を視覚的に確認するための、GUIソフトウェアについてもプロトタイプの開発を行った。認証・認可基盤の検証では、単に成功・失敗の結果を見るのではなく、どの時点でどの状態がどの入力によって変化したかを把握することが重要である。そのため、攻撃のシナリオやその実行結果をタイムラインUIとして時系列的に可視化し、時間経過やセッション状態、状態遷移の流れを追跡しやすくすることを目指している。

また、将来的には、このタイムラインUI上で、攻撃シナリオを編集できるように、開発者やレビュアーが必要に応じて検証内容を調整、追加できるようにしたいと考えている。これにより、可視化だけではなく、攻撃シナリオの確認と調整を一体的に行えるシステムへと発展できると考えている。さらに、この可視化結果をCIと連携させ、Pull Requestのコメント欄等に自動的に付与することで、実装者・レビュアー・プロジェクトマネージャーが、変更差分に対応する検証結果を開発フローの中で直接確認できるようにしたいと考えている。

2. どんな出し方を考えているか

本プロジェクトの成果物は、認証・認可基盤の安全性確認を支援する実用的な開発支援ツールとして、オープンソースとして公開する。その際には、実際の開発現場で容易に導入できる形を重視する。すでに 1.5.4 で述べた通り、GitHub Actions上での実行を見据えたプロトタイプ開発を進めている。

3 斬新さの主張・期待される効果など

3.1 既存手法との違い

動作を検証する手法として、真っ先に思い浮かぶのが単体テストや結合テスト、E2Eテストによる検証である。これはアプリケーション開発では一般的な手法であり、個々の関数や、複数の処理を組み合わせた機能単位の正しさを確認する上で非常に有効な手法である。リファクタリングなど、ソースコードに変更を加える場合でも、その変更が正しいものであるということを証明する手段となる。また、テストコードも含んでPull Requestを作成することが一般的であり、こういった条件をテストしたかをレビュアーが確認することもできるほか、実装者が自信を持ってレビュー依頼をするための材料であるという考え方もある。

しかし、認証・認可基盤においては、これらの手法だけでは十分に扱いにくい問題がある。背景にて述べた通り、複数の要素が相互に関係しながら動作するためである。時間経過に伴う状態変化は、通常の単体テストや結合テストでは検証しにくい。

また、認可処理を単純な状態遷移モデルとして抽象化し、網羅的に検証する方法も考えられるが、認証・認可基盤では、セッション、トークン、時間経過、再送などが組み合わさり、入力すべき事項や副作用が非常に多いという

性質を抱えるほか、1.5.2のように、素朴なモデルでは状態数が急速に増大し、探索量が爆発しやすいという課題がある。

このように、既存の一般的なテスト手法は個別機能の確認には有効である一方で、認証・認可基盤に特有の時間依存を含む問題を、実装に即して継続的に検証するには限界である。

3.2 新規性

本プロジェクトの新規性は、認証・認可基盤の実装コードを静的解析し、攻撃シナリオを実行可能な軽量サンドボックス環境を自動生成する点にある。従来のように、検証のための抽象モデルや専用のテストコードを別途人手で用意するのではなく、実装コードそのものを出発点として、認可処理の流れを抽出し、実行可能な検証環境として再構築する。

また、本プロジェクトでは、認証・認可基盤を開発する上で重要となる、時間経過に伴う処理の変化や、認可に関わる各種情報のバリデーション、ルーティング、リダイレクトを検証対象として明示的に扱う。特にトークンの有効期限やセッションの変化など、時間依存の挙動をシミュレーションし、人工的な時間進行によって検証可能にする点は、通常の単体テストや結合テストでは扱いにくい領域に対応するものである。

さらに本提案は単なる解析や単発実行にとどまらず、GitHub Actions等による継続的インテグレーション環境での実行や、GUIによる状態遷移・時間進行の可視化までを含めて設計している。これにより、認証・認可基盤に対する攻撃検証を、実際の開発プロセスの中で、継続的に利用できる形へと発展させる。

以上の点から、本プロジェクトは、認証・認可基盤に特有の問題を、実装に即した形で継続的に検証可能にする、新しい開発支援手法であると考えている。

3.3 なぜ形式的・機械的な手法で挑むのか

近年、生成AIはプログラムの実装補助、コードレビュー支援、テストコード生成など、ソフトウェア開発のさまざまな場面で用いられるようになってきている。認証・認可基盤の実装においても、設計、実装案の検討、テストケースの作成において、生成AIは有用な道具となりつつある。

一方で、認証・認可基盤の安全性において重要なのは、同じ前提条件で同じ結果を再現でき、かつ継続的に比較可能な形で検証できることである。システム開発において、透明性のある検証が必要な領域であり、再現性と一貫性が強く求められるのである。

そのため、本プロジェクトは生成AIと対立するものではなく、むしろ生成AIを開発現場において最大限に活用するための道具となることを目指す。実装コードを静的解析し、攻撃検証可能なサンドボックス環境を自動生成する本提案の仕組みは、生成AIが支援した実装に対しても、安全性を確認できる基盤として機能し、生成AIが出力したプログラムを信頼して本番環境に取り込むためのツールとしても機能することを狙う。

3.4 期待される効果

3.4.1 開発チームメンバー(実装者)の視点として

認証・認可基盤の実装は複雑であり、実装者自身が「どこまで安全性を検証できるか」を把握しづらい場合がある。本プロジェクトにより、実装コードをもとに攻撃シナリオを機械的に生成、実行できるようになれば、開発チームメンバーは、自らが加えた変更に対して、認可特有の問題が発生していないかを確認しやすくなる。また、単に正常系が動作することだけではなく、攻撃シナリオを通じて異常系を踏まえた検証結果を、容易にPull Requestに添えて提示できるため、レビュー依頼の段階で自信を持って変更内容を提出しやすくなる。これは認証・認可基盤のように慎重な実装が求められる領域において、実装者の心理的負担を軽減する効果も期待できる。

3.4.2 開発チームリーダー(レビュアー)の視点として

レビュアーにとって、認証・認可基盤の変更や修正が安全であるかを判断することは容易ではない。本プロジェクトにより、Pull Request上で攻撃シナリオと、その実行結果を確認できるようになれば、レビュアーは通常のコードレビューに加えて、どの条件で安全性を検証したのかを把握しやすくなる。さらに、GUIによって攻撃シナリオの時間

進行が可視化されることで、攻撃シナリオの内容も理解しやすくなり、認証・認可基盤のレビューをより根拠あるものにできると考えている。

3.4.3 開発に関与する経営・責任者の視点として

認証・認可基盤は、そのサービスのセキュリティの中核を担うため、万が一の不備はアカウントに紐づいたデータの漏洩や権限奪取につながる。その一方で、十分な検証を行うことは時間・金銭面でコストがかかり、負担になりやすい状況にあった。

本プロジェクトによって、認証・認可基盤の安全性確認をより容易に行えるようになれば、検証コストを抑えつつ、事故リスクを軽減する判断材料を得やすくなる。これによって、開発スピードと安全性の両立を求められる現場において、組織的な意思決定を支えるツールとして意義があると考えている。

4から8章は印刷省略